

VAKA KAYDI

Vaka Numarası: MALW-2026-0910-01 (malware sample triyajı, MalwareBazaar'dan alınan AgentTesla downloader)

Açılış Tarihi ve Durum:

Açılış: 2026-09-10

Durum: Kapalı (statik analiz + tespit kuralı tamamlandı)

TLP Etiketi:

TLP: CLEAR (herkese açık MalwareBazaar örneği, kurum içi veri yok)

Kısa Özet:

MalwareBazaar'dan alınan bir .docm belgesi (SHA256: 8c491ff716a5b1fca672bc23db6308d080bc3aba37f7b217364f7e1a2b9e8d7c, AgentTesla ailesi olarak etiketlenmiş). Belge açılınca Document_Open otomatik tetikleniyor, bir PowerShell scripti (Y1.ps1) indirip gizli pencerede çalıştırıyor. Kaynak kod ile derlenmiş p-code arasında isim uyumsuzluğu (VBA stompig şüphesi) tespit edildi; davranış her iki gösterimde de aynı.

Gözlemlenebilirler (Observables):

Tür	Değer	Not
Hash (SHA256)	8c491ff716a5b1fca672bc23db6308d080bc3aba37f7b217364f7e1a2b9e8d7c	Örnek dosya, doğrulandı
URL	hxxps://cloud-storag[e].art/doc/Y1.ps1	Payload indirme adresi
Dosya adı	Y1.ps1	İndirilen PowerShell scripti
Dosya yolu	C:\Temp\Y1.ps1	Diske yazıldığı konum
Malware ailesi	AgentTesla	

Yürütülen Görevler:

- Hash doğrulaması (indirilen dosya = ilan edilen hash)
- oleid ile hızlı üçgen (makro var, şüpheli, HIGH risk)
- olevba --decode --deobf ile makro kodu çıkarıldı
- olevba --show-pcode ile kaynak kod / p-code karşılaştırması yapıldı
- any.run sandbox raporu incelendi
- YARA kuralı yazıldı, örneğe ve iki ayrı temiz metne karşı test edildi

Zaman Çizelgesi:

Tarih	Olay	Kaynak
2025-12-18	Örnek MalwareBazaar'a yüklendi (abuse_ch)	MalwareBazaar
2025-12-18 14:56	any.run sandbox analizi çalıştırıldı (128 sn)	any.run
2026-09-10	Statik analiz ve YARA kuralı bu vaka kapsamında yapıldı	Kendi analiz

Statik Analiz Bulguları:

Otomatik çalışma:

Private Sub Document_Open()
Belge açılınca kullanıcı müdahalesi olmadan tetikleniyor.

Zincir:

- MSXML2.XMLHTTP ile hxxps://cloud-storag[e].art/doc/Y1.ps1 adresine GET isteği
- Yanıt C:\Temp\Y1.ps1 olarak diske yazılıyor
- WScript.Shell.Run ile PowerShell “-NoProfile -ExecutionPolicy RemoteSigned -File” C:\Temp\Y1.ps1 gizli pencerede (0) çalıştırılıyor.

VBA Stomping:

olevba, kaynak kod ile p-code arasında fonksiyon/değişken isim uyumsuzluğu tespit etti (Document_Open vs DownloadScript, Sub t() vs InitializeEnvironment).
Davranış (URL, dosya yolu, komut) her iki gösterimde birebir aynı; isim uyumsuzluğu davranışı değiştirmiyor, ama statik tarama araçlarını şaşırtmak için kullanılmış olabilir.

Statik Analiz vs Sandbox Karşılaştırması:

any.run raporu "No threats detected" gösterdi. Sebep, davranışın zararsız olması değil: sandbox içinde Word belgeyi "bozuk" olarak işaretleyip açamadı, Document_Open hiç tetiklenmedi, PowerShell/Y1.ps1'e dair hiçbir iz yok. Gözlenen HTTP trafiğinin tamamı Word'ün kendi telemetri/lisans trafiği (officeclient.microsoft.com, ocs.digicert.com, login.live.com), makronun hedefiyle ilgisi yok. Örnek Aralık 2025 tarihli olduğu için hedef domain (cloud-storage.art) muhtemelen artık ayakta değil; bu, sandbox'ın zinciri tamamlayamamasının bir başka olası sebebi. Karar sandbox skoruna değil, statik analizdeki doğrulanmış niyete dayanıyor.

IOC Listesi

Tür	Değer	Değerlendirme
Hash	8c491ff716a5b1fca672bc23db6308d080bc3aba37f7b217364f7e1a2b9e8d7c	Confirmed malicious
Domain	cloud-storag[e].art	Confirmed malicious (payload kaynağı), muhtemelen artık pasif
Dosya adı	Y1.ps1	Confirmed malicious payload
Dosya yolu	C:\Temp\Y1.ps1	Persistence/execution konumu

MITRE ATT&CK Eşlemesi

Teknik Adı	ID	Gözlemlenen Davranış
User Execution: Malicious File	T1204.002	Kullanıcının .docm dosyasını açması
Command and Scripting Interpreter: Visual Basic	T1059.005	Document_Open makrosu
Ingress Tool Transfer	T1105	MSXML2.XMLHTTP ile Y1.ps1 indirme
Command and Scripting Interpreter: PowerShell	T1059.001	Y1.ps1'in gizli pencerede çalıştırılması
Obfuscated Files or Information	T1027	VBA stomp (kaynak/p-code isim uyumsuzluğu)

Tespit Kuralı:

```
yara
rule AgentTesla_Docm_Y1_Downloader
{
  meta:
    description = "Detects macro downloader fetching Y1.ps1 from cloud-storage.art"
    author = "Gaye Nur Gunes"
    date = "2026-09-10"
    hash = "8c491ff716a5b1fca672bc23db6308d080bc3aba37f7b217364f7e1a2b9e8d7c"
    reference = "MalwareBazaar"

  strings:
    $url = "cloud-storage.art" nocase
    $payload = "Y1.ps1" nocase
    $http_obj = "MSXML2.XMLHTTP" nocase
    $ps_flag = "ExecutionPolicy RemoteSigned" nocase

  condition:
    $url and $payload and 1 of ($http_obj, $ps_flag)
}
```

Test sonuçları: Örneğin içinden çıkarılan vbaProject.bin'e eşleşti; iki ayrı temiz/zararsız metin dosyasına (biri WScript.Shell/MSXML2.XMLHTTP gibi genel terimleri içeren bir sahte pozitif testi dahil) eşleşmedi.

Not: kural ham .docm dosyasına değil, zip'ten çıkarılmış vbaProject.bin'e karşı eşleşiyor, string'ler dış zip sıkıştırması yüzünden ham dosyada görünmüyor.

Lab Güvenlik Adımları:

Analiz öncesinde olectools ve yara, ağ hâlâ açıkken kuruldu. Ardından VirtualBox üzerinde temiz bir kontrol noktası için snapshot alındı ("öncesi-makro-analiz"). Sonrasında VM'in ağ adaptörü host-only/kapalı moda çekilerek internet erişimi kesildi; örnek dosyanın açılması, hash doğrulaması, oleid, olevba ve YARA testleri bu izole ortamda yapıldı.

Bir istisna oldu: ağ kesildikten sonra unzip, MalwareBazaar arşivinin AES (v5.1) şifrelemesini açamadığı için p7zip paketinin kurulması gerekti. Bu amaçla ağ geçici olarak tekrar açıldı, sadece paket kurulumu yapıldı (örnek dosyaya bu sırada hiçbir işlem uygulanmadı), sonra ağ tekrar host-only moda çekilip kapatıldı ve arşiv açma/analiz buradan itibaren izole ortamda devam etti.

Sandbox raporu (any.run) ve hash sorgusu (MalwareBazaar arama) ana makinenin tarayıcısından yapıldı; VM'den ana makineye yalnızca metin (hash değeri, sandbox linki) geçti, dosyanın kendisi VM dışına hiç çıkmadı.

Karar

- Gerçek Pozitif
- **Öncelik:** Yüksek (aktif tehdit altyapısı muhtemelen pasif, ama davranış zinciri kanıtlı kötü niyetli)
- **Yapılan / Devredilen:** Statik analiz tamamlandı, tespit kuralı yazıldı ve test edildi. Sandbox'ın "no threats" sonucu, statik analiz bulgularıyla çelişmediği not edilerek geçersiz kılındı.